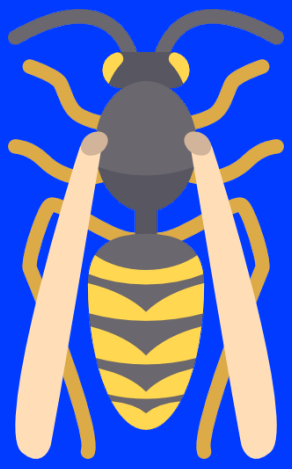
{EPITECH}

HACK & JUICE_

< A PENTEST A DAY KEEPS THE HACKERS AWAY. />



HACK & JUICE

OWASP

The Open Worldwide Application Security Project® (OWASP) is a nonprofit foundation that works to improve the security of software. Through community-led open source software projects, hundreds of local chapters worldwide, tens of thousands of members, and leading educational and training conferences, the OWASP Foundation is the source for developers and technologists to secure the web.

OWASP Top10 2025

The OWASP Top10 is a standard awareness document for developers and web application security. It represents a broad consensus about the most critical security risks to web applications.

1 - Broken Access Control	2 - Security Misconfiguration
3 - Software Supply Chain Failures	4 - Cryptographic Failures
5 - Injection	6 - Insecure Design
7 - Authentication Failures	8 - Software or Data Integrity Failures
9 - Security Logging and Alerting Failures	10 - Mishandling of Exceptional Conditions

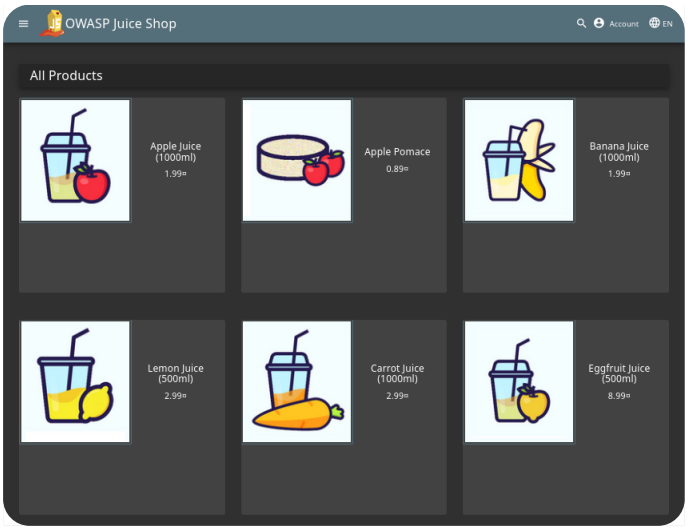
x

- OWASP Top10 2025

Juice Shop

The OWASP Juice Shop is an application written with the goal of showcasing a vast number of the vulnerabilities from the OWASP Top 10 along with many other security flaws found in real-world applications.

It is a perfect tool to try and take on hacking challenges of varying difficulty and has been used in security trainings, awareness demos and as a guinea pig for security tools.



The Hack & Juice is a CTF based around this project.
All challenges will be found on the platform https://juicepce1.cyber.epitest.eu.
You will be auto-registered based on your group on intra.epitech.eu.

Once the CTF starts, you will be able to spawn your very own instance of Juice Shop to start hacking!

Objectives

You have to train, test and improve your pen testing skills by tampering with this application. You should solve as many challenges as possible. We expect from each group member to solve and document **more than 15 of difficulty 3** (or higher) (at least).

The challenges are classified using different **categories** (corresponding to the OWASP Top 10 categories) and various **tags** (such as “Brute force”, “OSINT”, “Code analysis”...).

You should try challenges with different tags. This will make it more fun and expand your pen testing skills.

Each challenge is sorted by category on the CTFd and you can find their difficulty on their info card

Delivery

Documentation

At the root of your repository, you should provide **documentation and reports** about your pen testing results. You must submit one file for each challenge solved. The files are named as follows : `categoryName-difficultyLevel-challengeName.md`.

For instance:

✓ "`Broken Access Control-3-CSRF.md`" and "`Broken authentication-4-Login Bjoern.md`" are valid ;
- but `"Cross Site Scripting (XSS)-CSP Bypass-4.md"` and `"4-User Credentials-Injection.md"` are not.

> You do not need to document your solved challenge of difficulty strictly lower than 3.
> But you should understand how they work and be able to reproduce them.

Each of your markdown files addresses at least the following points:

✓ **methodology**:
- number the steps followed (1, 2, 3, ..),
- describe accurately your techniques (OSINT, enumeration, scan, brute force, ...),
- name the tools you used (search engine, SQLmap, Burp, bash script, password list, ...).

✓ **vulnerabilities**:
- name the vulnerability (injection, XSS, misconfiguration, CWE 502, ...),
- name the affected components (database, authentication system, ...),
- try to estimate its severity level (low, medium, high, critical).

✓ **risks**:
- describe its business impact (data leak, reputational damage, ...).

✓ **actions**:
- propose some risks mitigation strategies,
- suggest remediation fixes,
- recommend some related best security practices.

Optionally, each file could contain or be linked to some **evidences and artifacts**, such as screenshots, files (logs, scripts), traffic captures, ...
Some hacking challenges come with an additional coding challenge (after you've completed the challenge) where finding and fixing the responsible code flaw can be trained. These could help you for your documentation process.

Presentation

You'll have to briefly (10 min) **present the ins and outs of your project**, including:

- ✓ a description of the application's structure and workflows ;
- ✓ a presentation of your score board, indicating the number of challenges solved ;
- ✓ some insights on your repository, containing the documentation of solved challenges ;
- ✓ your thoughts and remarks, such as the skills you acquired, the obstacles you overcame, etc.

Then, the staff will ask each group member to thoroughly explain (>5 min) a challenge you solved. **The challenge choice is at your reviewer's discretion**. You have to provide a detailed explanation (including methodology & findings), adapted to the audience (by simplifying technical terms & complex concepts). You also have to answer several technical questions.

Live demonstrations would simultaneously illustrate your explanations and prove your skills.

The evaluators will probably:

- ✓ not ask who solved the challenge. And if they do, they surely want to know what the other guy has to say!
- ✓ ask you to explain a challenge you solved but didn't document!

Rules

You MUST NOT submit write-ups or solutions online.
You MUST NOT share solutions between groups.
You SHOULD NOT look for solutions online (clues are OK, solutions are NOT).
Not respecting these basic rules will spoil the fun and cause you trouble.

If your group decides to solve the challenges individually, you **must** ensure that each member is able to explain (and re-solve) the challenges solved by the others.
Finding the solutions, from other groups or internet, without being able to reproduce it is totally useless and will be easily detected.

> Any solution meant to help is a learning students won't get!
>
> **— Pierre ROBERT —**

v 1.1

{EPITECH}